

Finding Exposed VPNs

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

• **Find VPNs** that are exposed to the Internet

Finding Exposed VPNs

Mapping out target infrastructure and targeting VPNs.

WHY DO WE EVEN CARE?

We care because a VPN is the gateway to their internal network. That is a company's biggest fear, due to:

- Persistence
- Stealing sensitive data
- Deploying ransomware

Hacking a web application is likely to be in its own separate network in a DMZ. If you can map out and exploit their VPNs, it's game over.

The examples shown here are perfectly **legal**. The site is either intended to be **scanned**, or is a part of a **bug bounty** where the scope here is perfectly fine.

See: [Bugcrowd - Tesla Engagement](#)

Strategy 1: Map out target infrastructure and find VPNs (ONLY IF SELF-HOSTED):

1. MAP OUT THE TARGET'S FULL IP RANGE.

- Find the main domain and ping it to get the IP address.

Command	Details
<code>ping testphp.vulnweb.com</code>	Retrieves the IP address of the target domain.

2. PERFORM A REVERSE DNS LOOKUP ON THE IP TO SEE THE CORRESPONDING DOMAIN NAME.

Command	Example Output
<code>dig -x 44.228.249.3</code>	3.249.228.44.in-addr.arpa. 0 IN PTR ec2-44-228-249-3.us-west-2.compute.amazonaws.com.

In the output, you can easily see this is an EC2 instance hosted in Amazon.

3. RUN WHOIS TO DETERMINE OWNERSHIP AND GET THE FULL IP RANGE.

Command	Details
<code>whois 44.228.249.3</code>	Reveals ownership details and the full IP range.

4. SCAN THE FULL IP RANGE.

- Assuming this is self-hosted infrastructure, scan the entire IP range with either `nmap` or `rustscan`.
- Recommendation: Use `rustscan`, as it is much faster.

Scan for VPN Ports

When scanning the identified IP range, look for these specific ports to locate VPNs or potential jump boxes:

Port	Purpose
UDP 500	IKE (Internet Key Exchange)
UDP 4500	IPSEC NAT-Traversal Mode
443	SSL VPN
3389	RDP (Remote Desktop Protocol)
22	SSH (Secure Shell, often used for jump boxes)

These are common ports for either **VPN-based** or **UDP-based VPNs**, and ports **22** and **3389** are used in the case of jump boxes for the targeted organization. All of this is valuable data to have if you want to access the internal network of a company during an **ethical penetration test**.

Afterward, resolve the **IPs** with `dnsx` or `dig -x` and save them to a list for **domains**. Save all **IPs** elsewhere. You can scan the **domains** with `httpx` as shown above, while **IPs** are better suited for `nuclei` due to potential issues with **self-signed certificates** when scanning exposed **VPNs** using `httpx`.

This technique will not work in scenarios where the infrastructure is hosted by **Cloudflare** or in the cloud, as cloud ranges are used by more than one company. Unless the company is hosting the infrastructure themselves, which some do, be careful with scanning out of scope. Pay close attention to the **Netname**, **OrgName**, and **Route** fields in the `whois` lookup.

Strategy 2: Map out target infrastructure and find VPNs (If not self-hosted, but works either way)

1. TOOLS AND SETUP

If you're having issues downloading tools, additional information can be found at the bottom of this document.

2. FIND PASSIVE DNS RELATED DOMAINS FOR THE TARGET

Use the following commands to find subdomains related to the target domain (in this case, `tesla.com`).

Command	Details
<code>subfinder -all -silent -d tesla.com dnsx -silent tee subdomains.txt</code>	Finds all subdomains related to <code>tesla.com</code> and saves them to a file.

3. CHECK FOR SENSITIVE KEYWORDS IN SUBDOMAINS

You can use `grep` to search for sensitive keywords (such as VPN-related terms) in the `subdomains` file.

Command	Details
<code>grep -Ei "vpn cisco citrix forti forticlient Outlook login" subdomains.txt</code>	Looks for sensitive keywords like VPNs, Cisco, Citrix, etc., in the list of subdomains.

EXAMPLE OUTPUT:

In this example, we found 8 exposed live VPN-related domains for `tesla.com`:

Subdomain
<code>apacvpn.tesla.com</code>
<code>apacvpn1.tesla.com</code>
<code>apacvpn2.tesla.com</code>
<code>cnvpn1.tesla.com</code>
<code>cnvpn.tesla.com</code>
<code>vpn2.tesla.com</code>
<code>vpn1.tesla.com</code>
<code>vpn3.tesla.com</code>

Using `httpx` to Check for Sensitive Exposed VPNs, Emails, or Login Panels

You can use `httpx` to check for sensitive exposed VPNs, email servers, or general login panels by searching the HTML response of the page for certain keywords. Here's the command to do that:

Command	Details
<pre>cat subdomains.txt httpx -sc -title -mr "\bVpn\b \bCisco\b \bCitrix\b \bForti forticlient \bOutlook\b \blogin\b \bGlobalProtect\b \bAzureAttend\b" -p 80,443,8000,8080,8443 -follow-redirects tee vpn.txt</pre>	This command checks the HTML response of the listed subdomains for sensitive keywords (VPNs, login panels, etc.) and logs the results in vpn.txt. It scans common ports and follows redirects.

ISSUE WITH HTTPX AND SELF-SIGNED CERTIFICATES

httpx has an issue where it won't accept self-signed certificates. This is problematic because many VPNs are exposed with self-signed certificates. Fortunately, we have a workaround using **Nuclei**.

NUCLEI WORKAROUND

Command	Details
<pre>nuclei -no-interactsh -nh -stats -follow-host-redirects -l "httpx_domains.clean" -o "nuclei-results.txt" -t "/opt/tools/test.yaml" -vv</pre>	This command uses Nuclei to target domains and subdomains from the httpx_domains.clean file, running against the template test.yaml, and outputs the results to nuclei-results.txt.

Important Notes:

- httpx_domains.clean contains the list of domains and subdomains to target.
- test.yaml is the Nuclei template you will use during this scan.

This process allows you to bypass the limitations of **httpx** regarding self-signed certificates, making it easier to scan and identify exposed VPNs and login panels.

This is an excellent methodology for uncovering a company's most valuable treasures. Stay tuned! Many more guides are on the way!

VPN Keyword Checker

id: keyword-checker

info:

name: VPN Keyword Checker

author: Your Name

severity: info

description: Checks for the presence of VPN-related keywords and URLs in the response body.

tags: tech, cisco, vpn, forticlient, forti

requests:

- method: GET

path:

- "{{BaseURL}}/"
- "{{BaseURL}}/vpn"
- "{{BaseURL}}/remote"
- "{{BaseURL}}/owa"

redirects: true

max-redirects: 4

matchers:

- type: word

words:

- "Cisco"
- "forticlient"
- "Citrix"
- "VPN"
- "Forti"
- "Outlook"
- "CSCOE"
- "GlobalProtect"
- "+webvpn+"
- "AzureAttend"

condition: or
part: response

extractors:

- type: regex
part: response
regex:
 - '(?i)Cisco'
 - '(?i)forticlient'
 - '(?i)Citrix'
 - '(?i)VPN'
 - '(?i)Forti'
 - '(?i)Outlook'
 - '(?i)CSCOE'
 - '(?i)GlobalProtect'
 - '(?i)webvpn'
 - '(?i)AzureAttend'

- method: GET
path:
 - "{{BaseURL}}/"

matchers:

 - type: word
words:
 - "top.location=window.location;top.location="
 - "window.location.href="
 - "document.location="

condition: or
part: response

extractors:

- type: regex
part: response
regex:

- '(?i)top.location=window.location;top.location='
- '(?i>window.location.href='
- '(?i)document.location='

Instructions

1. Save the above content as test.yaml on your local system.
2. Run the following command, replacing the path with where you saved the file:

```
-t "/opt/tools/test.yaml"
```

Setting Up Tools

1. Subfinder

Install Subfinder using the following command:

Command	Details
<code>apt install subfinder -y</code>	Installs Subfinder on your system.

2. DNSX

Install DNSX using the following command:

Command	Details
<code>apt install dnsx -y</code>	Installs DNSX on your system.

3. HTTPX

To install HTTPX, follow these steps:

Step	Command
Remove any existing version	<code>rm /usr/bin/httpx</code>
Download the latest version	<code>wget https://github.com/projectdiscovery/httpx/releases/download/v1.6.9/httpx_1.6.9_linux_amd64.zip</code>

Step	Command
Unzip the downloaded file	<code>unzip httpx_1.6.9_linux_amd64.zip</code>
Move the HTTPX binary to the proper directory	<code>cp httpx /usr/bin/httpx</code>